

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 21

Domain I - Information Security Governance

27 Questions	43 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 43 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM6-001)

How does effective information security governance contribute to resource optimization?

- A. It directs equal security spending to every business process.
- B. It maximizes the number of security technologies purchased.
- C. It transfers all funding decisions to the information security department.
- D. It prioritizes capabilities and investments according to enterprise objectives and risk.

Question 2 (CISM6-002)

Scenario: A warehouse operator rewards sites that report zero security incidents. Managers have begun reclassifying events as operational issues to protect their performance ratings.

What should the information security manager recommend FIRST?

- A. Restrict incident reporting to the central security team.
- B. Increase penalties for sites that report incidents.
- C. Replace the zero-incident target with measures that reward timely, accurate reporting and effective treatment.
- D. Assume that low reported incident volume demonstrates strong controls.

Question 3 (CISM6-003)

Scenario: A clinical research company must preserve certain study records under contract while a hypothetical jurisdictional rule requires deletion of personal data when it is no longer necessary. Business teams have adopted indefinite retention for all records.

What is the BEST governance response?

- A. Obtain authoritative interpretations, classify record obligations, and approve accountable retention and deletion rules.
- B. Retain every record indefinitely to avoid accidental noncompliance.
- C. Let individual researchers choose retention periods without oversight.
- D. Delete every record immediately because privacy requirements always override contracts.

Question 4 (CISM6-004)

Which governance artifact is MOST useful for clarifying who is accountable, responsible, consulted, and informed for security activities?

- A. A responsibility assignment matrix
- B. A vulnerability scan
- C. A network configuration diagram
- D. A software inventory

Question 5 (CISM6-005)

Scenario: The security governance director owns the enterprise policy, approves all exceptions, operates the compliance monitoring process, and issues the independent opinion on policy effectiveness.

What is the GREATEST governance concern?

- A. The policy may contain too few technical details.
- B. Exception requests may take longer to document.
- C. Operational ownership and independent assurance are combined, weakening objectivity.
- D. Compliance monitoring should never involve the security function.

Question 6 (CISM6-006)

Scenario: An equipment manufacturer is moving from product sales to subscription-based maintenance services. Architects are defining customer processes, equipment telemetry, applications, and partner interfaces.

What should the information security manager do at this stage?

- A. Wait until the subscription platform is operational before reviewing risk.
- B. Identify security requirements and information risks as part of capability and architecture decisions.
- C. Require the service to use every control designed for the former sales model.
- D. Select security products without consulting architecture stakeholders.

Question 7 (CISM6-007)

Which information is MOST useful to a governing body overseeing information security?

- A. Every individual event generated by security monitoring tools
- B. Material risk trends, strategic outcomes, tolerance breaches, and decisions requiring authority
- C. Detailed configuration settings for all enterprise devices
- D. Only incidents that have already caused a reported financial loss

Question 8 (CISM6-008)

Scenario: A public records organization plans to outsource document storage. The proposed provider may use subcontractors, but the contract lacks approval rights, evidence access, deletion verification, and transition assistance.

Which recommendation is MOST appropriate?

- A. Define subcontractor obligations, assurance rights, verified disposition, accountability, and exit support before approval.
- B. Accept the terms because physical and digital storage are provider responsibilities.
- C. Transfer ownership of statutory obligations to the provider.
- D. Rely on the provider's public security statements instead of contract terms.

Question 9 (CISM6-009)

Scenario: Developers at a small online retailer can create code changes, approve them, deploy them to production, and delete the related deployment logs.

Which arrangement BEST addresses the governance risk while recognizing limited staffing?

- A. Allow developers to approve their own low-risk changes without logging.
- B. Require independent approval and protected logging, with timely review of emergency deployments.
- C. Prohibit all production changes until additional employees are hired.
- D. Give permanent production access to every developer to distribute responsibility.

Question 10 (CISM6-010)

Scenario: A transportation group acquires several local operators and inherits more than one hundred deviations from its approved architecture. Some support safety-critical services, while others belong to systems scheduled for near-term retirement.

What should the information security manager recommend FIRST?

- A. Remediate deviations alphabetically by system name.
- B. Accept all inherited deviations until integration is complete.
- C. Replace every nonconforming system before assessing operational impact.
- D. Prioritize deviations using business criticality, exposure, dependencies, target architecture, and remaining lifecycle.

Question 11 (CISM6-011)

What is the PRIMARY purpose of an information security strategy?

- A. To replace the enterprise strategy for information-dependent activities
- B. To list every technical setting used by operational teams
- C. To define how security capabilities and priorities will support enterprise goals and manage risk
- D. To document individual incident investigation steps

Question 12 (CISM6-012)

Scenario: A private education provider begins serving government agencies while its workforce shifts toward temporary instructors and external content partners.

Why should these developments influence the information security strategy?

- A. Only government customer expectations matter to security strategy.
- B. The customer base and workforce model change obligations, access patterns, dependencies, and capability needs.
- C. Temporary workers remove the need for long-term security planning.
- D. External partners should define the provider's enterprise risk appetite.

Question 13 (CISM6-013)

Scenario: A regional pharmacy chain wants essential dispensing services restored within an approved business timeframe. Current recovery capabilities vary by store, and no enterprise dependencies have been documented.

What should the information security manager do NEXT?

- A. Compare current capabilities and dependencies with the desired recovery outcome, then prioritize the gaps.
- B. Use the number of recovery products as the strategic success measure.
- C. Buy identical recovery technology for every store immediately.
- D. Allow each store to define unrelated recovery objectives.

Question 14 (CISM6-014)

Scenario: An investment cooperative already has established risk, audit, and policy processes. A sponsor proposes adding a new security framework as a separate system of governance with duplicate committees and reporting.

What is the BEST recommendation?

- A. Create all duplicate structures to prove full framework adoption.
- B. Map relevant framework practices to existing governance, identify gaps, and integrate only the needed changes.
- C. Replace every existing governance process regardless of effectiveness.
- D. Reject all framework guidance because governance processes already exist.

Question 15 (CISM6-015)

Scenario: A food processor loses funding midway through its roadmap. Remaining initiatives include a required customer-data commitment, a foundational asset ownership program, a cosmetic reporting redesign, and replacement of a low-risk tool.

Which response is MOST appropriate?

- A. Preserve mandatory and foundational work while deferring lower-value discretionary initiatives.
- B. Protect the initiative with the most senior sponsor.
- C. Cancel every multiyear initiative and retain only operational spending.
- D. Reduce each initiative by the same percentage.

Question 16 (CISM6-016)

Scenario: Sales executives support stronger customer-data controls in principle, but their compensation rewards launch speed exclusively. They repeatedly defer the process changes required by the approved security strategy.

What is the MOST important governance issue?

- A. The security team needs more detailed configuration standards.
- B. Sales executives should be excluded from data governance.
- C. Leadership incentives and accountability are not aligned with the approved strategic outcome.
- D. The strategy should remove all initiatives that affect launch speed.

Question 17 (CISM6-017)

Scenario: A media archive plans automated data protection decisions before establishing information ownership, classification criteria, or authoritative repositories.

How should the roadmap be adjusted?

- A. Establish ownership, classification, and authoritative information sources before dependent automation.
- B. Run all initiatives without shared milestones.
- C. Deploy automation first because it will define ownership automatically.
- D. Remove information governance because it is not a technical capability.

Question 18 (CISM6-018)

Scenario: A digital ticketing company seeks to reduce disruption caused by compromised administrator accounts. Its dashboard reports the number of authentication policies published.

Which metric BEST demonstrates progress toward the strategic outcome?

- A. The number of pages in each authentication policy
- B. The frequency and business duration of disruptions involving compromised administrator access
- C. The total number of policy documents distributed
- D. The number of meetings held by identity administrators

Question 19 (CISM6-019)

Scenario: A property insurer will consolidate claims applications into a shared platform over three years. Current proposals fund separate long-term security services for each retiring application.

What should the information security manager recommend?

- A. Remove existing protections as soon as consolidation is approved.
- B. Renew every legacy service for the maximum available term.
- C. Shift investment toward shared target capabilities while maintaining proportionate interim protection during migration.
- D. Let each application team define a separate target security architecture.

Question 20 (CISM6-020)

Scenario: A mining company needs security architecture expertise for a two-year modernization. It lacks internal specialists, but long-term ownership must remain with enterprise staff.

What is the MOST appropriate resource approach?

- A. Abandon architecture governance until permanent specialists are hired.
- B. Use temporary expertise with defined knowledge transfer, internal ownership, and oversight.
- C. Give external consultants authority to accept all enterprise risk.
- D. Purchase architecture software as a substitute for skilled judgment.

Question 21 (CISM6-021)

What is the PRIMARY purpose of a key risk indicator?

- A. To document every task completed by the security team
- B. To replace management judgment with an automatic decision
- C. To signal changes in exposure that may require attention or action
- D. To measure employee satisfaction with security technology

Question 22 (CISM6-022)

Scenario: A credit union is comparing three identity modernization options. The least expensive has high integration risk, the fastest creates long-term vendor dependency, and the third costs more initially but aligns with the approved architecture and business expansion.

How should the information security manager guide the decision?

- A. Choose the option with the lowest purchase price.
- B. Choose the fastest option because schedule always outweighs lifecycle risk.
- C. Select the option preferred by the largest technical team.
- D. Compare expected outcomes, risk reduction, lifecycle cost, architecture fit, dependencies, and exit flexibility.

Question 23 (CISM6-023)

Scenario: A business unit requests a temporary exception from a security standard for a seasonal service. Current policy allows exceptions but does not define approval authority or expiration.

What should the information security manager establish FIRST?

- A. A rule requiring internal audit to own all exception decisions
- B. Automatic approval for every request described as temporary
- C. Permanent acceptance for services that generate revenue
- D. Risk-based approval thresholds, accountable owners, treatment requirements, expiration, and review criteria

Question 24 (CISM6-024)

Scenario: A construction firm reports that its security roadmap is successful because spending and project completion are on plan. At the same time, critical supplier access exceptions continue to rise beyond approved thresholds.

What is the MOST appropriate conclusion?

- A. Output measures are masking an adverse risk outcome that requires strategy and initiative review.
- B. Supplier exceptions should be excluded from strategic reporting.
- C. The roadmap is effective because its financial measures are favorable.
- D. Higher spending will necessarily resolve the exposure.

Question 25 (CISM6-025)

Scenario: A streaming service defines a maximum acceptable duration for disruption of paid customer access. The limit is derived from its broader low appetite for customer-facing outages.

How should the defined limit be used?

- A. As an optional target with no governance consequence
- B. As a substitute for all scenario and impact analysis
- C. As evidence that shorter outages require no management attention
- D. As a measurable boundary for monitoring, escalation, and treatment decisions

Question 26 (CISM6-026)

Scenario: A major service disruption reveals that a regional airline's security strategy underestimated dependencies on a single external scheduling provider. Immediate recovery is complete.

What should the information security manager do NEXT?

- A. Close the matter because operations have recovered.
- B. Limit follow-up to disciplinary action against operational personnel.
- C. Review strategic assumptions, concentration exposure, resilience objectives, sourcing, and roadmap priorities.
- D. Replace every external provider regardless of criticality.

Question 27 (CISM6-027)

Scenario: A digital health company plans to enter several markets, consolidate patient services onto a common platform, and rely on local processing partners. Leaders have proposed separate investments without assessing cross-border obligations or architecture dependencies.

What should the information security manager recommend FIRST?

- A. Select technology before defining information and governance requirements.
- B. Approve all proposals because each supports at least one stakeholder.
- C. Allow each market to develop an unrelated enterprise security strategy.
- D. Bring authorized stakeholders together to align market objectives, obligations, risk appetite, architecture, capabilities, and investments.

Answer Key

Domain I - Information Security Governance

1 D	2 C	3 A	4 A	5 C
6 B	7 B	8 A	9 B	10 D
11 C	12 B	13 A	14 B	15 A
16 C	17 A	18 B	19 C	20 B
21 C	22 D	23 D	24 A	25 D
26 C	27 D			

Detailed Explanations

Question 1 (CISM6-001)

Correct answer: D - It prioritizes capabilities and investments according to enterprise objectives and risk.

Effective governance directs limited resources toward capabilities and investments that best support enterprise objectives and manage material risk. Equal spending ignores context, technology volume is not value, and funding decisions require appropriate enterprise participation rather than exclusive security ownership.

Question 2 (CISM6-002)

Correct answer: C - Replace the zero-incident target with measures that reward timely, accurate reporting and effective treatment.

The current incentive encourages concealment, so measures should reward transparency and effective response rather than apparent absence of events. Additional penalties deepen the bias, centralized reporting cannot reveal hidden events, and low volume is unreliable when incentives distort behavior.

Question 3 (CISM6-003)

Correct answer: A - Obtain authoritative interpretations, classify record obligations, and approve accountable retention and deletion rules.

Authoritative interpretation and record-specific rules allow the company to reconcile preservation and deletion duties with clear accountability. Blanket deletion or indefinite retention may violate applicable requirements, while individual discretion creates inconsistent and unauditable decisions.

Question 4 (CISM6-004)

Correct answer: A - A responsibility assignment matrix

A responsibility assignment matrix explicitly distinguishes accountability, responsibility, consultation, and notification. Scans, diagrams, and inventories provide operational or technical information but do not define decision and activity ownership.

Question 5 (CISM6-005)

Correct answer: C - Operational ownership and independent assurance are combined, weakening objectivity.

The director is assessing activities and decisions under the same director's control, which undermines independent assurance. Policy detail and documentation time are secondary, and security may participate in monitoring as long as independent evaluation remains appropriately separated.

Question 6 (CISM6-006)

Correct answer: B - Identify security requirements and information risks as part of capability and architecture decisions.

The changed operating model creates new data flows and dependencies that should be governed during capability and architecture design. Waiting loses design opportunities, product selection is premature, and copying all legacy controls may not address the new service context.

Question 7 (CISM6-007)

Correct answer: B - Material risk trends, strategic outcomes, tolerance breaches, and decisions requiring authority

A governing body needs concise information about material exposure, strategy performance, risk boundaries, and decisions within its authority. Raw events and configurations are operational detail, while realized financial losses alone omit emerging risk and nonfinancial impact.

Question 8 (CISM6-008)

Correct answer: A - Define subcontractor obligations, assurance rights, verified disposition, accountability, and exit support before approval.

The contract should create enforceable oversight across subcontracting, assurance, disposition, and transition. Outsourcing operations does not remove the organization's accountability, and public claims cannot replace specific contractual rights and duties.

Question 9 (CISM6-009)

Correct answer: B - Require independent approval and protected logging, with timely review of emergency deployments.

Independent approval, protected evidence, and review of emergency activity provide practical separation and compensating oversight. Unlogged self-approval preserves the conflict, a total change freeze is impractical, and broader permanent access increases rather than reduces exposure.

Question 10 (CISM6-010)

Correct answer: D - Prioritize deviations using business criticality, exposure, dependencies, target architecture, and remaining lifecycle.

Risk-based prioritization directs resources toward deviations with the greatest business and security consequence while considering transition plans. Alphabetical ordering has no risk basis, blanket acceptance lacks oversight, and immediate universal replacement may disrupt critical services or waste investment.

Question 11 (CISM6-011)

Correct answer: C - To define how security capabilities and priorities will support enterprise goals and manage risk

The security strategy sets direction for capabilities and priorities that enable enterprise goals and manage risk. Technical settings and investigation steps belong in lower-level documentation, and security strategy aligns with rather than replaces enterprise strategy.

Question 12 (CISM6-012)

Correct answer: B - The customer base and workforce model change obligations, access patterns, dependencies, and capability needs.

Both customer and workforce changes affect obligations, stakeholders, access, dependencies, and desired capabilities. Focusing on only one factor is incomplete, temporary labor still requires strategic governance, and partners do not set the provider's risk appetite.

Question 13 (CISM6-013)

Correct answer: A - Compare current capabilities and dependencies with the desired recovery outcome, then prioritize the gaps.

A current-to-desired-state comparison identifies capability and dependency gaps that should drive prioritized initiatives. Product purchases should follow defined needs, technology counts do not measure restoration outcomes, and unrelated objectives undermine the approved enterprise requirement.

Question 14 (CISM6-014)

Correct answer: B - Map relevant framework practices to existing governance, identify gaps, and integrate only the needed changes.

Mapping and integrating relevant practices preserves effective structures while addressing real gaps and avoiding duplication. Creating parallel governance wastes resources, wholesale replacement ignores proven capabilities, and rejecting all guidance may overlook valuable improvements.

Question 15 (CISM6-015)

Correct answer: A - Preserve mandatory and foundational work while deferring lower-value discretionary initiatives.

Mandatory commitments and foundational capabilities carry greater strategic value and dependency than cosmetic or low-risk replacements. Equal cuts ignore relative importance, sponsor rank is not a value measure, and eliminating all strategic work undermines sustainable capability.

Question 16 (CISM6-016)

Correct answer: C - Leadership incentives and accountability are not aligned with the approved strategic outcome.

Conflicting incentives prevent stated sponsorship from becoming sustained action, so leadership must align accountability and performance expectations with the approved outcome. Technical standards do not fix incentives, excluding sales weakens ownership, and removing necessary controls sacrifices strategy to the misalignment.

Question 17 (CISM6-017)

Correct answer: A - Establish ownership, classification, and authoritative information sources before dependent automation.

Automation requires trustworthy ownership, classification, and source information, making those capabilities foundational dependencies. Technology cannot define business ownership by itself, uncoordinated execution increases failure risk, and information governance is central to sustainable security decisions.

Question 18 (CISM6-018)

Correct answer: B - The frequency and business duration of disruptions involving compromised administrator access

The frequency and duration of relevant disruptions measure the business risk outcome the strategy intends to improve. Document length, meetings, and distribution are activity or output measures that do not show increased resilience.

Question 19 (CISM6-019)

Correct answer: C - Shift investment toward shared target capabilities while maintaining proportionate interim protection during migration.

Investment should build reusable target-state capabilities while treating material transition risk. Long renewals may create stranded cost, immediate control removal creates exposure, and separate target architectures conflict with the approved consolidation.

Question 20 (CISM6-020)

Correct answer: B - Use temporary expertise with defined knowledge transfer, internal ownership, and oversight.

Temporary expertise combined with knowledge transfer and retained internal accountability addresses the immediate gap while building sustainable capability. Delaying governance exposes the program, consultants cannot accept enterprise risk, and software cannot replace experienced judgment.

Question 21 (CISM6-021)

Correct answer: C - To signal changes in exposure that may require attention or action

A key risk indicator provides an early or continuing signal that exposure is changing and may require management attention. Task counts are performance outputs, indicators inform rather than replace judgment, and satisfaction measures serve a different purpose unless directly tied to a defined risk.

Question 22 (CISM6-022)

Correct answer: D - Compare expected outcomes, risk reduction, lifecycle cost, architecture fit, dependencies, and exit flexibility.

A strategic business case must compare enterprise outcomes and risk across the full lifecycle, including architecture and exit implications. Initial price, speed, and team preference each capture only one dimension and can conceal material long-term exposure.

Question 23 (CISM6-023)

Correct answer: D - Risk-based approval thresholds, accountable owners, treatment requirements, expiration, and review criteria

A sustainable exception process requires authorized decisions, ownership, treatment, expiration, and review. A temporary label or revenue benefit does not justify automatic acceptance, and internal audit should independently assess rather than own management risk decisions.

Question 24 (CISM6-024)

Correct answer: A - Output measures are masking an adverse risk outcome that requires strategy and initiative review.

On-time spending and delivery are outputs, while increasing exceptions beyond thresholds indicate worsening exposure and possible strategic failure. Excluding the measure hides risk, and additional spending without analyzing causes and effectiveness may not improve the outcome.

Question 25 (CISM6-025)

Correct answer: D - As a measurable boundary for monitoring, escalation, and treatment decisions

The tolerance translates broad appetite into a measurable boundary that supports monitoring and escalation. It is not optional, does not make all exposure below it irrelevant, and informs rather than replaces management analysis.

Question 26 (CISM6-026)

Correct answer: C - Review strategic assumptions, concentration exposure, resilience objectives, sourcing, and roadmap priorities.

The incident exposed a strategic dependency that warrants review of assumptions, objectives, sourcing, and priorities after recovery. Closure would ignore the lesson, replacing every provider is disproportionate, and disciplinary action does not address the underlying concentration risk.

Question 27 (CISM6-027)

Correct answer: D - Bring authorized stakeholders together to align market objectives, obligations, risk appetite, architecture, capabilities, and investments.

Integrated governance is needed to reconcile expansion, obligations, local partners, target architecture, risk boundaries, and investment choices. Funding every proposal may create duplication, unrelated strategies weaken enterprise direction, and technology selection should follow defined business and security requirements.